

MIT AI Risk Repository

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 10: AI Threat Modeling Resources

1. What Is the MIT AI Risk Repository?

The MIT AI Risk Repository is a living, searchable knowledge base developed by researchers at the Massachusetts Institute of Technology. Unlike prioritized frameworks such as the OWASP Top 10 lists—which highlight the most critical risks—the MIT repository aims for breadth: cataloguing hundreds of AI-related risks across different technologies, industries, and stages of the AI development lifecycle.

The repository is continuously updated as the AI landscape evolves. New research findings, documented incidents, and emerging attack patterns are incorporated over time, making it a dynamic resource rather than a static checklist. Its primary value is helping organizations surface risks they might otherwise overlook during a threat modeling exercise—particularly those that fall outside the scope of focused Top 10 frameworks.

Think of it as the difference between a curated highlight reel and a comprehensive archive. The OWASP lists give you the greatest hits. The MIT repository gives you the full library, organized so you can navigate it systematically based on your specific technology, domain, and deployment context.

2. Repository Organization and Navigation

Navigating hundreds of AI risks without a clear structure would be unmanageable. The MIT AI Risk Repository addresses this by organizing risks along three primary dimensions, allowing security teams to filter results to what is most relevant for their environment.

Dimension	Filter Options	Practical Use
Risk Domain	Security, Privacy, Fairness, Transparency, Safety, Reliability	Focus on security and privacy risks for threat modeling exercises
AI Technology	Traditional ML, Large Language Models, Generative AI, Other AI Systems	Filter to the technology your organization actually deploys
AI Lifecycle Stage	Development, Training, Deployment, Operations, Retirement	Align risk review with the phase your project is currently in

This three-dimensional structure transforms a large research catalog into a practical decision-support tool. A security team evaluating an LLM deployment can filter to the LLM technology, security domain, and deployment stage—dramatically narrowing the list to risks that are directly applicable rather than theoretically possible.

3. Threat Modeling with the Repository

The MIT AI Risk Repository delivers its greatest value when used as part of a structured threat modeling exercise. A systematic review process ensures that relevant risks are identified, evaluated, and addressed before deployment rather than after an incident occurs.

- Identify your AI system — define the technology used, the business domain, the data involved, and the deployment architecture.
- Filter the repository — apply the relevant technology, domain, and lifecycle stage filters to narrow the risk catalog to applicable entries.
- Evaluate each risk — for each identified risk, ask: Does this apply to our system? How could it occur? What is the likely business impact?
- Map against existing controls — identify which risks are already covered by current security controls and where gaps remain.
- Prioritize gaps — rank uncovered risks by likelihood and impact to focus remediation effort where it delivers the most security value.
- Document and review — record the analysis and schedule periodic reviews as the AI system evolves and the repository is updated.

This systematic process prevents threat modeling from becoming a superficial review. Rather than affirming that obvious risks are known, the structured approach ensures that less visible risks are also examined and addressed.

4. Risk Categories: A Comparative Overview

The repository organizes individual risks into broader categories. Security professionals naturally gravitate toward security risks, but understanding adjacent categories is essential because challenges in one area often create vulnerabilities in another.

Category	Core Concern	Why It Matters to Security Teams
Security	Protecting AI systems from attacks	Direct scope: model theft, data poisoning, adversarial inputs
Privacy	Preventing sensitive data exposure	Privacy failures can expose training data containing PII or confidential information
Fairness	Addressing bias and discrimination	Biased models can create exploitable blind spots in security AI
Robustness	Reliable performance under change	Models that degrade under adversarial inputs become security liabilities
Transparency	Explainability and accountability	Opaque models make detecting manipulation or error much harder
Safety	Preventing harmful outcomes	Unsafe AI outputs can directly harm users or downstream systems

A security AI model that is technically robust against attacks but poorly understood by its operators (low transparency) is more likely to have misconfigured controls. Category boundaries are analytical conveniences, not firewalls. Real-world risks frequently span multiple categories simultaneously.

5. Real-World Incident Integration

Real-World Incident — Microsoft Tay Chatbot (2016): Microsoft deployed an AI chatbot named Tay on Twitter. Within 24 hours, adversarial users systematically fed the model offensive content, exploiting its reinforcement learning mechanism to produce harmful outputs. Microsoft withdrew the system within a day. This incident is documented in AI risk repositories as an example of how social manipulation combined with inadequate input filtering and output monitoring can corrupt deployed AI systems rapidly. The MIT AI Risk Repository captures this class of risk under security and safety domains.

Repository entries that include documented incidents provide more than historical context. They demonstrate failure patterns that recur across different organizations and technologies. Understanding why past failures occurred helps security teams recognize similar conditions in their own systems before they become incidents.

6. Mitigation Strategies: From Documentation to Practice

The MIT AI Risk Repository goes beyond cataloguing what can go wrong. Many entries also document practical mitigation strategies drawn from real-world experience, academic research, and industry practice. This dual structure makes the repository directly actionable.

- **Technical mitigations:** adversarial training, input validation, differential privacy, model monitoring, rate limiting on inference APIs, and access control enforcement.
- **Governance mitigations:** human oversight requirements, security review gates at lifecycle transitions, model documentation standards, and continuous post-deployment monitoring.
- **Process mitigations:** vendor assessment, third-party audits, red team exercises, supply chain validation, and incident response planning specific to AI failures.

The most effective use of these mitigation entries is comparative: map the repository's documented strategies against your organization's existing controls to identify where your security posture is strong and where gaps remain. This comparison produces a targeted security improvement backlog grounded in recognized best practice.

7. Analogy: The Repository as a Medical Diagnostic Reference

Memory Anchor: A physician does not use a complete diagnostic encyclopedia to treat every patient. But when facing an unusual presentation, the comprehensive reference reveals diagnoses that a prioritized checklist would never surface. The MIT AI Risk Repository works the same way. Focused frameworks like the OWASP Top 10 are your clinical guidelines for common conditions. The MIT repository is your complete diagnostic reference for when the usual answers are not enough.

Effective AI security practice means knowing when to use each resource. Routine threat modeling may begin with the OWASP lists. Novel deployment contexts, unusual architectures, or unfamiliar AI technologies warrant a broader search, and that is precisely when the depth of the MIT repository becomes indispensable.

8. Staying Current: Quarterly Review Discipline

The AI threat landscape evolves faster than most traditional software domains. New attack techniques are discovered, new AI capabilities are released, and real-world incidents add to the body of knowledge continuously. The MIT AI Risk Repository is designed to grow alongside these developments, but organizations must establish a process to benefit from updates.

Security teams that treat the repository as a one-time input risk operating on outdated threat models. Best practice involves scheduling formal repository reviews on a regular cadence, typically quarterly, and also triggering ad hoc reviews following significant changes to AI systems or after major disclosed incidents in the industry.

This discipline should be formalized: assign ownership to a named role, integrate repository reviews into existing risk management governance, and ensure that new repository entries are evaluated against both current and planned AI deployments. Continuous awareness is the difference between a threat model that reflects the current landscape and one that reflects how things stood eighteen months ago.

9. Integrating the Repository with Other Frameworks

No single framework provides complete AI security coverage. Experienced practitioners combine multiple frameworks to achieve both the depth needed for high-priority risks and the breadth needed to avoid overlooking less common threats.

Framework	Primary Focus	Complementary Role
OWASP ML Top 10	Most critical machine learning risks	Prioritized starting points; repository expands coverage beyond the top 10
OWASP LLM Top 10	LLM-specific vulnerabilities	Depth on LLM risks; repository adds breadth across all AI technologies
MITRE ATLAS	Adversary tactics and techniques against AI	Attacker perspective and TTPs; repository provides broader risk context
MIT AI Risk Repository	Comprehensive AI risk catalog	Breadth and real-world evidence; other frameworks provide priority and attacker views

The combination of OWASP (priority), MITRE ATLAS (adversary behavior), and the MIT repository (breadth) gives security teams a well-rounded foundation. These are complementary tools designed for different aspects of the same security challenge.

10. Risk Communication and Organizational Alignment

Technical risk assessments create value only when they inform decisions. The MIT AI Risk Repository supports better risk communication by providing well-documented descriptions, supporting research citations, and real-world incident evidence that decision-makers can evaluate objectively.

Instead of presenting an AI risk as a subjective concern, security teams can reference specific repository entries backed by research and documented precedent. This transforms security discussions from

opinion-based debate to evidence-grounded analysis, which is a much more effective basis for securing budget and executive support.

The repository also provides a shared vocabulary. When security engineers, AI developers, compliance professionals, and business leaders all reference the same terminology and documented risk categories, communication becomes more precise. Misunderstandings about what a risk means or how serious it is become less common when everyone is working from the same authoritative source.

11. Customizing the Repository for Your Environment

The MIT AI Risk Repository is intentionally comprehensive. Its value is breadth, not pre-applied prioritization for your specific environment. Effective use therefore requires customization.

- Filter by technology: limit the initial review to risk entries relevant to the AI systems your organization actually deploys.
- Filter by domain: focus on risk categories most relevant to your industry, such as security and reliability for a cybersecurity company or privacy and fairness for a healthcare provider.
- Apply regulatory context: overlay applicable regulations such as GDPR, HIPAA, NIS2, or sector-specific AI regulations to identify risks with compliance implications.
- Score and prioritize: assess each remaining risk for likelihood in your environment and potential business impact, then rank remediation priorities accordingly.
- Maintain a living risk register: document the customized list, assign owners, and review it on the same cadence as repository updates.

12. Repository Limitations and Responsible Use

Understanding what the MIT AI Risk Repository is and what it is not prevents misuse and unrealistic expectations. The repository is a risk identification and awareness resource, not a complete security implementation guide.

- Coverage gaps: rapidly emerging attack techniques may not yet be documented. The repository reflects what is known and published, not every possible future risk.
- Implementation depth: risk entries describe what can go wrong and general mitigation approaches, but they do not replace detailed engineering guidance for specific technologies.
- Relevance filtering required: not every documented risk is relevant to every organization. Applying the repository without filtering produces noise rather than actionable insight.
- Not a compliance checklist: the repository is a risk awareness resource, not a regulatory standard. Meeting compliance requirements requires additional domain-specific guidance.

Key Terms Glossary

Term	Definition
MIT AI Risk Repository	A living, searchable catalog of AI-related risks maintained by MIT researchers, covering hundreds of risks across technologies, lifecycle stages, and domains.
Risk Domain	A broad category used to organize AI risks in the repository;

	examples include security, privacy, fairness, robustness, transparency, and safety.
AI Lifecycle Stage	A phase in the development and operation of an AI system (development, training, deployment, operations, retirement) used to filter relevant risks.
Living Repository	A continuously updated knowledge base that incorporates new research, incidents, and evolving best practices rather than remaining static.
Threat Modeling	A structured process of identifying, categorizing, and evaluating potential threats to a system so that security controls can be designed and prioritized effectively.
Mitigation Strategy	A documented approach to reducing the likelihood or impact of a specific risk, such as adversarial training, input validation, or human oversight requirements.
Risk Communication	The practice of presenting security findings in terms that support informed decision-making by technical and non-technical stakeholders.
OWASP ML Top 10	A prioritized list of the most critical machine learning security risks, published by the Open Web Application Security Project.
MITRE ATLAS	A knowledge base documenting adversary tactics and techniques used against AI systems, analogous to the MITRE ATT&CK framework for traditional cybersecurity.
Risk Register	A documented record of identified risks, their owners, likelihood and impact assessments, and the status of mitigation efforts.

Quick Revision Checklist

- The MIT AI Risk Repository is a living catalog of hundreds of AI risks, not a prioritized Top 10 list.
- Risks are organized by domain (security, privacy, fairness, etc.), AI technology, and lifecycle stage.
- Use the repository during structured threat modeling to surface risks that focused frameworks may miss.
- Many entries include both real-world incident documentation and practical mitigation strategies.
- Integrate the repository with OWASP lists and MITRE ATLAS for breadth, priority, and adversary perspective together.
- Customize the repository by filtering to your specific technology, domain, and regulatory context.
- Schedule quarterly reviews to keep threat models aligned with repository updates and new incidents.
- Use repository entries to support evidence-based risk communication with executives and compliance teams.
- The repository identifies risks and general mitigations but does not replace detailed engineering implementation guides.
- Treat repository-documented risks as a knowledge base to inform decision-making, not a definitive compliance checklist.

10 Exam-Based MCQs — MIT AI Risk Repository

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. *Scenario:* Aisha is a security architect at a financial services company deploying a traditional machine learning model for transaction fraud detection. Her CISO has asked her to conduct a comprehensive AI threat modeling exercise that goes beyond the OWASP ML Top 10. Which action should the security architect take FIRST to use the MIT AI Risk Repository effectively?

- A) Review all documented risks in the repository regardless of technology type
- B) Filter the repository by AI technology, business domain, and lifecycle stage
- C) Replace the OWASP ML Top 10 with the repository as the primary threat model input
- D) Use the repository only after a security incident has occurred

Answer: B **Explanation:** B is correct because the repository is intentionally comprehensive; effective use requires filtering by technology, domain, and lifecycle stage to surface relevant risks without overwhelming the team. A is wrong because reviewing all risks regardless of relevance creates noise and wastes effort. C is wrong because the repository complements focused frameworks like OWASP and does not replace them. D is wrong because the repository's primary value is proactive risk identification before incidents, not post-incident analysis.

Q2. *Scenario:* Marcus is preparing a training presentation for his security team on AI threat modeling resources. He needs to clearly explain the difference between the OWASP ML Top 10 and the MIT AI Risk Repository so team members know when to use each one. What does the MIT AI Risk Repository offer that the OWASP ML Top 10 does not?

- A) Prioritized ranking of the most critical machine learning risks
- B) Comprehensive coverage of hundreds of AI risks across technologies and domains
- C) Detailed step-by-step implementation guidance for specific mitigations
- D) A compliance checklist aligned with GDPR and HIPAA requirements

Answer: B **Explanation:** B is correct because the MIT repository's distinguishing value is broad coverage across hundreds of risks, technologies, and domains rather than prioritization. A is wrong because prioritization is exactly what the OWASP Top 10 provides, not the MIT repository. C is wrong because the repository provides general mitigation strategies, not detailed engineering implementation guides. D is wrong because the repository is a risk awareness resource, not a compliance checklist.

Q3. *Scenario:* The security operations team at a cybersecurity company has just completed its first AI threat model using the MIT AI Risk Repository for a newly deployed threat detection system. The CISO is asking how the team plans to maintain the threat model going forward. How should the security team integrate the repository review into their ongoing security program?

- A) Conduct a single comprehensive review during initial deployment and rely on it indefinitely
- B) Review the repository only when a new AI vulnerability is publicly disclosed
- C) Schedule quarterly repository reviews and trigger ad hoc reviews after significant AI changes

D) Delegate repository reviews entirely to AI development teams without security involvement

Answer: C **Explanation:** C is correct because the repository is a living resource that evolves with the AI threat landscape; regular scheduled reviews combined with event-triggered ad hoc reviews keep threat models aligned with current knowledge. A is wrong because a one-time review allows threat models to become outdated as the repository and threat landscape evolve. B is wrong because waiting for public disclosures is reactive and misses risk categories not captured in CVE announcements. D is wrong because security teams must be involved in risk evaluation — delegating entirely to AI developers removes the security perspective.

Q4. Which of the following BEST describes what qualifies an AI risk for inclusion in the MIT AI Risk Repository?

- A) Only risks that have been exploited in documented public incidents
- B) Only risks that affect machine learning systems, not Large Language Models
- C) Risks across AI technologies, lifecycle stages, and domains identified through research and incidents
- D) Only risks that have an associated CVE identifier

Answer: C **Explanation:** C is correct because the repository catalogs AI risks broadly across technologies, lifecycle stages, and domains, sourced from research findings, documented incidents, and evolving best practices. A is wrong because the repository includes theoretical and research-documented risks, not only confirmed public incidents. B is wrong because the repository covers traditional ML, LLMs, and other AI systems. D is wrong because CVE identifiers relate to software vulnerability tracking, which is a separate system.

Q5. Which primary benefit do the real-world incident references in the MIT AI Risk Repository provide?

- A) They provide legal precedents for AI liability determinations
- B) They demonstrate how specific risks have materialized, supporting practical understanding and risk communication
- C) They list organizations that are non-compliant with AI security standards
- D) They provide step-by-step technical reproduction instructions for security researchers

Answer: B **Explanation:** B is correct because incident documentation transforms abstract risk descriptions into concrete examples of how risks manifest in practice, which both improves understanding and strengthens risk communication with stakeholders. A is wrong because the repository does not address legal liability. C is wrong because incident examples document what happened, not compliance status. D is wrong because the repository does not provide exploitation reproduction instructions.

Q6. Why is focusing only on the Security risk category insufficient when using the MIT AI Risk Repository for AI threat modeling?

- A) Because the Security category contains fewer entries than other categories

- B) Because risks in categories such as Privacy and Robustness can directly affect security outcomes
- C) Because the repository does not actually include a Security risk domain
- D) Because security risks are already fully covered by the OWASP ML Top 10

Answer: B **Explanation:** B is correct because AI risk categories are interconnected. Privacy failures can expose training data, robustness weaknesses can be exploited adversarially, and transparency limitations can mask compromised model behavior. A is wrong because the number of entries per category is not the reason; interconnection is. C is wrong because Security is explicitly listed as one of the primary risk domains. D is wrong because OWASP covers the most critical risks but does not eliminate the need for broader analysis.

Q7. Which of the following is the most appropriate use of the repository's documented mitigation strategies?

- A) Directly implementing every documented mitigation regardless of applicability
- B) Comparing repository mitigations with existing organizational controls to identify gaps
- C) Using mitigation documentation as a substitute for security engineering consultation
- D) Treating repository mitigations as mandatory compliance requirements

Answer: B **Explanation:** B is correct because comparing documented mitigations against existing controls is the appropriate use; it produces a targeted gap analysis rather than unfocused implementation of every possible control. A is wrong because implementing every mitigation regardless of applicability wastes resources and may introduce unnecessary complexity. C is wrong because repository documentation supplements but does not replace security engineering expertise. D is wrong because repository mitigations are best-practice guidance, not mandatory regulatory requirements.

Q8. An organization's AI threat model was completed two years ago using the MIT AI Risk Repository. What is the most significant risk of not updating it?

- A) The repository has completely changed its categorization scheme, making the old analysis incompatible
- B) New attack techniques, incidents, and research may have surfaced risks not captured in the original model
- C) The organization's compliance certifications will automatically expire without model updates
- D) All previously identified risks will no longer be valid

Answer: B **Explanation:** B is correct because the AI threat landscape evolves rapidly and the repository is updated continuously; risks that were not documented two years ago may now be well-understood, and new incidents may reveal failure modes not previously recognized. A is wrong because repository categorization changes are evolutionary, not complete replacements that invalidate prior analysis. C is wrong because threat model currency is not directly tied to compliance certification expiry. D is wrong because previously identified risks generally remain valid even as new ones are added.

Q9. How does the MIT AI Risk Repository support risk communication with non-technical executives?

- A) By automatically generating executive summary reports
- B) By providing research-backed risk descriptions and incident evidence that support objective security discussions
- C) By replacing internal risk assessments with externally verified conclusions
- D) By ranking risks by financial impact in monetary terms

Answer: B **Explanation:** B is correct because well-documented risk descriptions and real-world incident evidence transform security conversations from subjective opinion into evidence-grounded analysis, which is more persuasive with decision-makers. A is wrong because the repository does not generate automated reports; that is an organizational process task. C is wrong because internal assessment remains necessary. D is wrong because the repository does not provide financial impact quantification.

Q10. Which combination of frameworks provides the most comprehensive foundation for AI security threat modeling?

- A) OWASP ML Top 10 alone, because it covers all significant AI risks
- B) MITRE ATLAS alone, because it documents real-world attacker behavior
- C) OWASP lists for prioritized risks, MITRE ATLAS for adversary behavior, and MIT repository for broad coverage
- D) The MIT repository alone, because it is the most comprehensive AI risk resource available

Answer: C **Explanation:** C is correct because the three frameworks serve complementary roles: OWASP provides prioritized starting points, MITRE ATLAS maps attacker tactics and techniques, and the MIT repository provides broad coverage across hundreds of risks. Together they deliver both depth and breadth. A is wrong because the OWASP Top 10 is intentionally focused on critical risks and does not provide comprehensive coverage. B is wrong because ATLAS focuses on adversary behavior rather than comprehensive risk cataloging. D is wrong because even the MIT repository does not capture the adversary-perspective depth that MITRE ATLAS provides.